API Contracts & Event Catalog

JSON Schema examples, status-code policy, webhook envelope and versioning

1. API contract policy

The OpenAPI document is the canonical source for REST behavior. DTO types should be generated from or checked against it. Request schemas reject unknown fields on security-sensitive endpoints; response schemas are stable, versioned contracts.

1.1 Example JSON Schema: create checkout session

```
{
  "$schema": "https://json-schema.org/draft/2020-12/schema",
  "title": "CreateCheckoutSessionRequest",
  "type": "object",
  "additionalProperties": false,
  "required": ["customerId", "items", "successUrl", "cancelUrl"],
  "properties": {
    "customerId": { "type": "string", "pattern": "^cus_[A-Za-z0-9]+$" },
    "items": {
      "type": "array", "minItems": 1, "maxItems": 50,
      "items": {
        "type": "object", "additionalProperties": false,
        "required": ["priceId", "quantity"],
        "properties": {
          "priceId": { "type": "string", "pattern": "^price_[A-Za-z0-9]+$" },
          "quantity": { "type": "integer", "minimum": 1, "maximum": 1000 }
        }
      }
    },
    "successUrl": { "type": "string", "format": "uri", "maxLength": 2048 },
    "cancelUrl": { "type": "string", "format": "uri", "maxLength": 2048 },
    "affiliateCode": { "type": "string", "maxLength": 100 }
  }
}
```

1.2 Example JSON Schema: checkout session response

```
{
  "$schema": "https://json-schema.org/draft/2020-12/schema",
  "title": "CheckoutSessionResponse",
  "type": "object",
  "additionalProperties": false,
  "required": ["id", "status", "currency", "totalMinor", "checkoutUrl", "expiresAt"],
  "properties": {
    "id": { "type": "string", "pattern": "^cs_[A-Za-z0-9]+$" },
    "status": { "enum": ["pending", "completed", "expired", "cancelled"] },
    "currency": { "type": "string", "minLength": 3, "maxLength": 3 },
    "totalMinor": { "type": "integer", "minimum": 0 },
    "checkoutUrl": { "type": "string", "format": "uri" },
    "expiresAt": { "type": "string", "format": "date-time" }
  }
}
```

2. Standard status code policy

Code	Meaning	Client action
200	Read/update succeeded	Use returned DTO.
201	Resource created	Store returned ID and DTO.
202	Accepted for asynchronous processing	Poll resource or await webhook; do not assume completed.
204	Succeeded with no response body	No JSON parsing.
400	Malformed or schema-invalid request	Fix request; no retry.
401	Missing/invalid authentication	Refresh identity session once if supported.
403	Insufficient permission	No retry.

Code	Meaning	Client action
404	Not found within authorized scope	Treat as unavailable; avoid cross-tenant existence leakage.
409	Idempotency or state conflict	Fetch current state or use a new operation key only after inspection.
422	Business validation failed	Show actionable validation error.
429	Rate limited	Honor Retry-After.
5xx	Transient or internal error	Retry only under idempotency/safety rules.

3. Event envelope

```
type CpgEvent<T> = {
  id: string;                // Unique event ID
  type: string;              // e.g. payment.succeeded
  tenantId: string;
  occurredAt: string;
  apiVersion: string;
  data: T;
  requestId?: string;
};
```

Webhook deliveries include a timestamp and signature header defined by the platform's signing scheme. Consumers must verify signature, deduplicate event IDs, acknowledge only after durable acceptance, and process asynchronously. Events are at-least-once; consumers must not assume exactly-once delivery.

4. Recommended event catalog

Event	Producer	Consumers / effect
order.paid	Orders/Payments orchestration	Billing, entitlement, fulfillment, affiliate conversion.
payment.succeeded	Payments	Order state, ledger posting, downstream outbox.
payment.failed	Payments	Checkout status, dunning if renewal.
refund.updated	Payments	Ledger adjustment, entitlement policy, affiliate reversal.
invoice.finalized	Billing	Payment collection, invoice notification.
subscription.renewed	Billing	Entitlement extension and analytics.
subscription.cancelled	Billing	Entitlement expiry/revocation policy.
usage.accepted	Usage	Aggregation worker.
credits.consumed	Credits	Usage reporting and audit.
entitlement.granted	Entitlements	Downstream cache invalidation or access provisioning.
delivery.failed	Distribution	Retry queue and operations alert.
license.activated	Licenses	Audit and tenant reporting.
affiliate.commission_adjusted	Affiliates	Affiliate report and payable liability.

5. API versioning and compatibility

- Prefix routes with /api/v1; make additive optional fields backward-compatible.
- Do not change enum meanings or field units silently. New enum values can still break exhaustive client switches; document and test them.

- Use a deprecation window for removals and announce replacement routes.
- Keep public IDs stable. Internal Mongo ObjectIds should not be required by client integrations.
- Version webhook payloads separately or include apiVersion in each event.
- Run OpenAPI diff checks in CI and fail builds for unapproved breaking changes.